Daikin (HVAC controllers / SVMPC remote controllers)

Daikin (HVAC controllers / SVMPC remote controllers) — Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory (OSINT) research only — **no firmware or software has been acquired or extracted for this vendor.** Every finding below comes from public vulnerability disclosures (NVD, CISA ICS advisories, vendor PSIRT) and product documentation. CVE IDs listed in the Confirmed table were each independently re-verified against NVD/CISA/vendor records before inclusion; candidate IDs that could not be confirmed were dropped, not guessed.

Identity

Field	Value
Census / OUI string	`Daikin Industries, Ltd.`
Operating company	Daikin Industries, Ltd. (Osaka, Japan) is the parent. In the US the OT-relevant arm is Daikin Applied Americas Inc. (Minneapolis, MN; formerly McQuay International / AAF-McQuay), which builds applied HVAC and the MicroTech building-automation controllers. Light-commercial/residential networked product ships through Daikin North America LLC / Daikin Comfort Technologies (Goodman/Amana/Daikin One). Two sibling Daikin entities own the products behind the confirmed CVEs: Daikin Europe N.V. (Security Gateway) and Daikin Holdings Singapore Pte Ltd (SVMPC VRV management controllers).
OT devices (ARNG census)	16 across 7 states
Genuine OT vendor?	Yes
Purdue placement	Levels 1-2 of a facility-related control system (FRCS/BAS) enclave. MicroTech unit controllers and VRV field controls are Level 1 (field/unit controllers on serial or IP fieldbus); VRV central controllers (iTM), BAS integration gateways and the Daikin Security Gateway/SVMPC web-managed controllers are Level 2 (supervisory/area control). A site BAS front-end (e.g., Tridium Niagara) and any Daikin cloud link sit at Level 2/3 and the enclave boundary; the Daikin cloud itself is off-premises.

Identity note. Census string maps cleanly to IEEE OUI 00:80:4F = DAIKIN INDUSTRIES, LTD. (Electronics Division, Japan), a legacy MA-L 16M block assigned to genuine Daikin networked HVAC equipment — not a rebrand or a component-vendor artifact. Daikin is a holding structure: US applied/BAS gear is built by Daikin Applied Americas (ex-McQuay International, legacy OUI 00:D0:DB); the two CVE-bearing products come from sibling entities Daikin Europe N.V. (OUI 04:ED:62; Security Gateway) and Daikin Holdings Singapore (OUI 64:4E:EB; SVMPC controllers). A device booked under 'Daikin Industries, Ltd.' could therefore be any of these Daikin-family products; confirm the specific model/MAC to pick the right advisory.

Product lines & OT relevance

Genuine OT. Daikin is one of the world's largest HVAC/air-conditioning manufacturers and sells networked building-automation / HVAC control equipment that integrates into building-management systems (BMS/BAS) over BACnet, Modbus and LonWorks. In a US National Guard facility context these are facility-related control systems (FRCS): HVAC unit controllers, VRV/VRF central controls, chiller/air-handler controllers and remote-management gateways. OUI 00:80:4F is a genuine IEEE block registered to DAIKIN INDUSTRIES, LTD. (Electronics Division, Japan), a 16M-address MA-L assigned to real Daikin networked equipment — not an OUI artifact of a chip sitting inside someone else's product. 16 devices across 7 states is consistent with distributed HVAC/BAS controllers in National Guard armories and support facilities.

- MicroTech II/III/4 unit controllers (Rebel rooftop units, Applied Rooftop/self-contained, water-source heat pumps, fan coils, chillers, air handlers) with pluggable BACnet/Modbus/LonWorks communication modules (BACnet/IP + Modbus IP comm module per IM 916-7; BACnet MS/TP per IM 917-4; LonWorks modules)
- VRV/VRF central and remote controls: VRV Controls Network, Intelligent Touch Manager / iTM, DKN Plus interface (Modbus, BACnet MS/TP, Cloud API, DKN app)
- Daikin Security Gateway (Daikin Europe N.V.) — web-managed VRV/equipment remote-access gateway (subject of CVE-2025-10127)
- SVMPC1 / SVMPC2 VRV management controllers (Daikin Holdings Singapore) with office + remote controller web UIs (subject of CVE-2022-41653 / CVE-2022-38355)
- Daikin One / DKN Cloud light-commercial & residential connected thermostats and cloud-managed indoor units (OTA firmware)
- Third-party protocol gateways commonly paired with Daikin units (Intesis/HMS Networks, Chipkin, BACnet/Modbus/LonWorks translators) — not Daikin-branded but frequently present on the same segment

Attack surface

- BACnet/IP over UDP 47808 (0xBAC0) and BACnet MS/TP over RS-485 serial — unauthenticated by protocol design; device/object enumeration and point writes possible if reachable
- Modbus TCP over TCP 502 and Modbus RTU serial — no authentication/integrity; register read/write to HVAC points if exposed
- LonWorks / LonTalk (TP/FT-10 twisted pair; LonWorks/IP tunneling on UDP 1628/1629) via comm modules
- HTTP/HTTPS embedded web management UIs on controllers and the Security Gateway — primary remote-exploit surface
- Default / hard-coded credentials: Daikin Security Gateway resets to username 'Daikin' / password 'Daikin' (CVE-2025-10127); SVMPC controllers ship a use-of-hard-coded-password flaw (CVE-2022-41653) that yields full control
- Unauthenticated information disclosure on the LAN from SVMPC controllers (CVE-2022-38355)
- Cloud/OTA connectivity: SVMPC and Security Gateway auto-update from Daikin cloud; DKN/Daikin One phone home — outbound internet egress and a cloud trust path that bypasses local controls
- Internet exposure: web-managed gateways/controllers are findable via Shodan/runZero fingerprints; vendor repeatedly advises they were never meant to be internet-facing

- Flat FRCS segments: Daikin controllers often share a VLAN with third-party BACnet/Modbus gateways (Intesis, Chipkin) and the BAS front-end, widening lateral movement

Confirmed CVEs / advisories

Each row was re-verified against an authoritative record (URL given). This is the public disclosure history, not an exhaustive list.

CVE / advisory	Applies to	Summary	Source
`CVE-2022-41653`	Directly a Daikin product (Daikin Holdings Singapore SVMPC1/SVMPC2 office + remote control	Use of a hard-coded password (CWE-259) in Daikin SVMPC1 (v2.1.22 and prior) and SVMPC2 (v1.2.3 and prior) VRV management controllers; a remote attacker can obta	https://nvd.nist.gov/vuln/detail/CVE-2022-41653
`CVE-2022-38355`	Same Daikin SVMPC product family and the same CISA advisory ICSA-22-284-02; relevant where	Improper access control (CWE-284) in the same Daikin SVMPC1/SVMPC2 controllers; an attacker on the LAN can access sensitive information without authentication.	https://www.cisa.gov/news-events/ics-advisories/icsa-22-284-02
`CVE-2025-10127`	Directly a Daikin product (Daikin Europe N.V. Security Gateway) under CISA advisory ICSA-2	Authorization bypass via user-controlled key / weak password recovery (CWE-640) in the Daikin Europe N.V. Security Gateway (App 100, Frm 214 and prior); an unau	https://nvd.nist.gov/vuln/detail/CVE-2025-10127

Detection guidance

- Inventory by OUI in passive/DHCP/ARP asset discovery: 00:80:4F (Daikin Industries, Ltd.), plus related Daikin-family blocks seen on Daikin gear — 04:ED:62 (Daikin Europe N.V.), 64:4E:EB (Daikin Holdings Singapore), 00:D0:DB (McQuay International, legacy Daikin Applied units)
- Monitor and baseline BACnet/IP UDP 47808, Modbus TCP 502, and LonWorks/IP UDP 1628-1629 on the FRCS enclave; alert on any of these crossing the enclave boundary or reaching the internet
- Fingerprint the Daikin Security Gateway with the runZero/Shodan HTTP signature: HTML title 'Security GW' with favicon mmh3 hash 1417553504; alert on any hit from an untrusted segment and specifically on POST to /api/settings/password/reset (the CVE-2025-10127 exploit path)
- Flag use of the default credential pair Daikin/Daikin on any Daikin web UI (indicates CVE-2025-10127 reset or unchanged defaults)
- Log sources: BAS supervisor/front-end (e.g., Tridium Niagara station logs), the FRCS enclave firewall (NGFW/BACnet-aware), any third-party gateway (Intesis/Chipkin) logs, and controller web/syslog where available; capture north-south flows to Daikin cloud FQDNs for egress baselining
- Allowlisting: restrict BACnet/Modbus so field controllers speak only to the designated BAS supervisor (specific device instance IDs / Modbus master IP); deny inbound to controller/gateway web UIs from everything except a management jump host; deny controller internet egress except explicitly required Daikin cloud endpoints (and prefer blocking cloud/OTA entirely where mission allows)

- Place Daikin controllers behind an FRCS firewall isolated from the business/IT network (per CISA guidance and DoD UFC 4-010-06 FRCS cybersecurity), and use a patched VPN for any remote BAS access rather than exposing web UIs

Acquisition status

We currently hold NO Daikin firmware or software. Documentation is largely OPEN: installation/operation manuals, protocol point lists and Modbus/BACnet register maps are freely downloadable from daikinapplied.com and tahoeweb.daikinapplied.com (e.g., IM 916-7, IM 917-4, ED 15112, ED 19133) and give the behavioral/register detail useful for detection without the binary. Firmware IMAGES are GATED: MicroTech controller/comm-module firmware and service tools (MicroTech Service Tool, DaikinCity dealer portal) are distributed through authorized Daikin Applied service/dealer channels, not public download. The Security Gateway and SVMPC controllers self-update from the Daikin cloud (ICSA-22-284-02 notes the fix installs automatically when internet is enabled) and Daikin Europe declined to patch CVE-2025-10127, so no public patch binary exists for it. Daikin One / DKN connected residential/light-commercial units update OTA via the cloud app. Net: expect open docs/point-maps but no obtainable firmware image without a dealer/service account or a physical device to dump.

Notes

All three CVEs were verified in THIS research by fetching the live CISA advisory pages (not recalled from memory): ICSA-22-284-02 for the two 2022 SVMPC CVEs and ICSA-25-254-10 for CVE-2025-10127. No CVE was found in public databases for the MicroTech controller line itself; its risk is protocol-level (unauthenticated BACnet/Modbus/LonWorks) rather than a named CVE. CVE-2025-10127 is the priority item: critical, trivially exploitable, public PoC, and vendor WONTFIX — mitigation is isolation only. Corroborating non-CISA references seen this session: runZero blog (Security GW fingerprint + default-cred detail) and a UAE Cyber Security Council / ADGM advisory; these were used for detection context, not as CVE sources.

Status

Item	State
Firmware/software acquired	**No** — OSINT/advisory only
Confirmed CVEs	3 (independently re-verified)
Behavioural baseline	None — no samples held
Next step	CISA/PSIRT deep pass; attempt firmware acquisition

Generated 2026-10-26 from the ot-vendor-briefs workflow (12 researchers + adversarial CVE verification). Device counts from the 2026-10-22 ARNG OT census.